

2.3 Cloud Security & Compliance

In this course, you will:

- Pinpoint the benefits of AWS cloud security and the vital role that AWS plays at organizational certification and attestation
- Investigate the specific services that help meet the criteria set by the ever-evolving laws, regulations, and privacy standards
- Explore programs used for compliance alignments and frameworks
- Demystify AWS Artifact, the CSA Consensus Assessment Initiative Questionnaire, and the AWS Compliance Solutions Guide, among other items

Network Access Control Lists (NACLs) in AWS

Cloud Security Benefits

- Leverages the secure infrastructure and best practices of AWS
- Inherits all best practices, policies, architecture, and operational processes
- Allows you to grow and innovate while preserving a compliant and secure environment
- Provides a variety of managed solutions to deliver security



Cloud Security Benefits



Assures that data is durable and safe



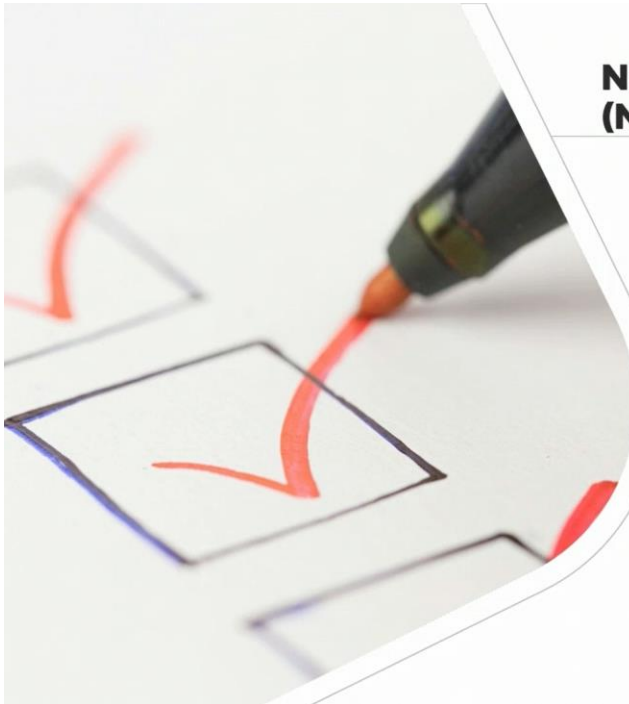
Lowers the total cost of ownership



Scales rapidly and securely



Adheres to compliance mandates



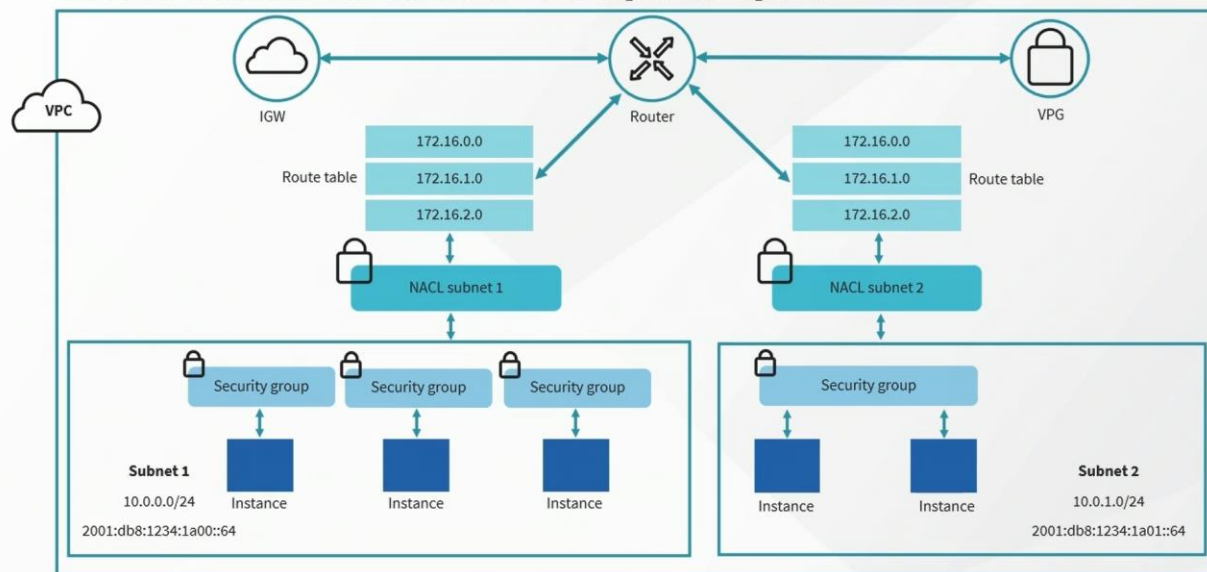
Network Access Control Lists (NACLs) in AWS

- An optional layer of security for the VPC that acts as a stateless (static) firewall for controlling traffic in/out of one or more subnets
- Can set up Layer 3/Layer 4 NACLs with rules to add an additional layer of security to VPC
- They apply to all instances within the subnet

Network Access Control Lists (NACLs) in AWS

- Can contain ordered rules to permit or deny traffic (rules are processed with a numbered order)
- Are agnostic of TCP sessions or UDP/ICMP flows
- Are stateless (static) in that the return traffic must be explicitly allowed in the other NACL
- Work together with security groups and can permit or deny traffic before it reaches the interfaces

Network Access Control Lists (NACLs) in AWS



Security Groups in AWS

Security Groups in AWS

- Apply to individual EC2 instances in a subnet
- Operate at the hypervisor level attached to the virtual elastic network interfaces (eth0)
- Layer 3/Layer4 stateful virtual "allow only" firewalls – no explicit deny rules
- All EC2 instances are launched with the default security group unless otherwise designated
- An unchanged default security group allows communication between all resources within the security group and all outbound traffic – all other traffic is implicitly denied

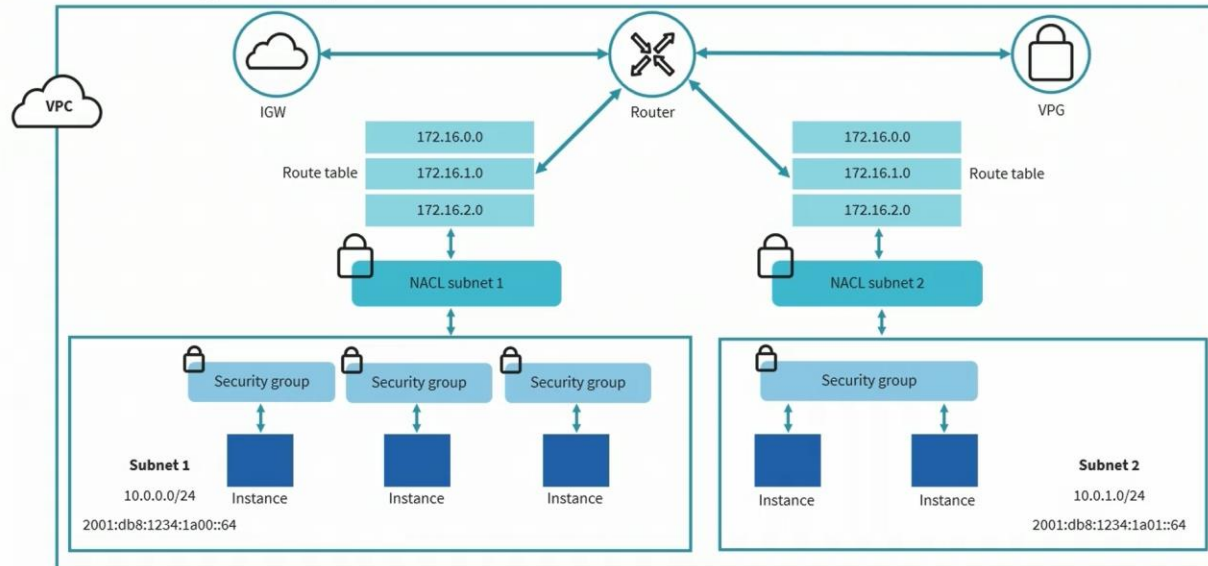


Security Groups in AWS

- Return traffic is automatically allowed (with AWS Shield Standard inspection)
- All rules in all applied security groups are evaluated before a decision is made
- You can only create a limited number of security groups on every VPC that you have
- There is also a limit on the number of rules you can add to one security group
- There is a limited number of security groups that you can use with a network interface



Security Groups in AWS



Security Groups vs. NACLs

Security group	Network ACL
Operates at the instance level	Operates at the subnet level
Supports allow rules only	Supports allow rules and deny rules
Is stateful – return traffic is automatically allowed, regardless of any rules	Is stateless – return traffic must be explicitly allowed by rules
We evaluate all rules before deciding whether to allow traffic	We process rules in order, starting with the lowest numbered rule when deciding whether to allow traffic
Applies to an instance only if someone specifies the security group when launching the instance, or associates the security group with the instance later	Automatically applies to all instances in the subnets that it's associated with (therefore, it provides an additional layer of defense if the security group rules are too permissive)

AWS Web Application Firewall (WAF)

AWS Web Application Firewall (WAF)

The AWS WAF lets you control and monitor the HTTP and HTTPS requests forwarded to Amazon CloudFront, application Elastic Load Balancing (ELB), or API Gateway.



AWS Web Application Firewall (WAF)



Permissive

Allow all the requests made through the WAF except for ones that you designate



Restrictive

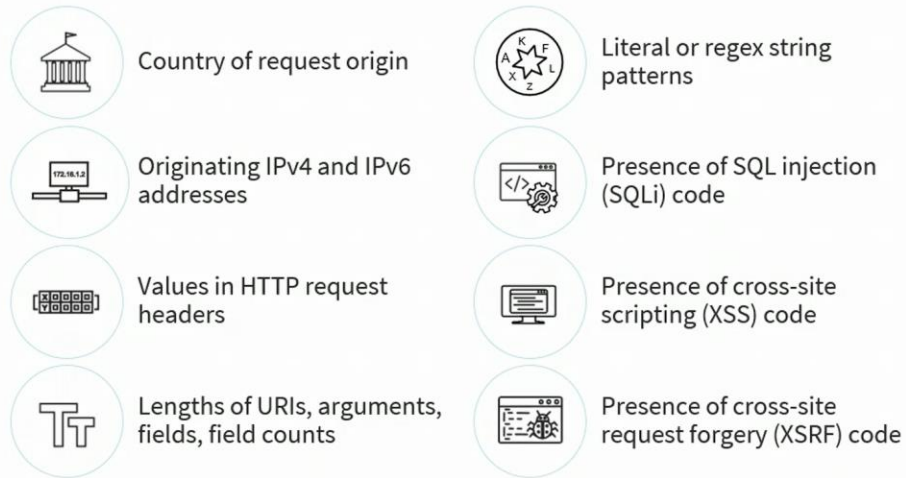
Block all the requests made through the WAF except for ones that you designate



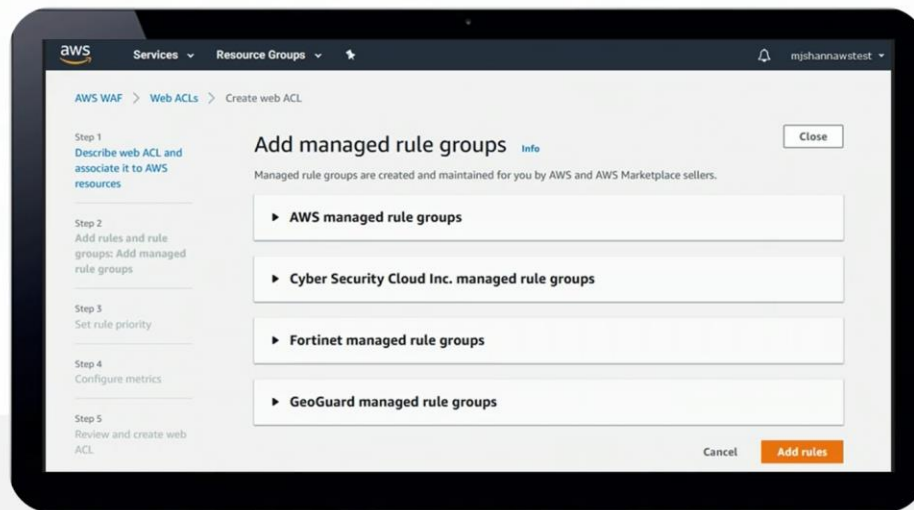
Counting

Count the requests that match the properties that you specify as a preliminary mode or set limits for HTTP requests

AWS WAF Conditions



AWS WAF Conditions



AWS Shield and Inspector

AWS Shield Standard

- AWS Shield Standard offers DoS and DDoS protection provided at no extra cost
- Provides basic protection against common DoS floods and exploits
- Most common DDoS comes from botnet servers
- Shield is often combined with NACLs, security groups, and WAF for layered defense



AWS Shield Advanced

- Expanded DDoS attack protection for a price (~\$3000 USD)
- For ELBs, CloudFront distributions, and Route 53 hosted zones
- 24x7 DDoS Response Team (DRT) assistance
- Access to advanced real-time metrics and deep visibility reporting
- Must have a Business, Enterprise On-Ramp, or Enterprise Support plan

Amazon Inspector

- An automated security assessment service that enhances the security and compliance of applications running on AWS
- Automatically evaluates applications for vulnerabilities and nonconformity with best practices



Amazon Inspector



Amazon GuardDuty

Amazon GuardDuty

- Fully-managed threat detection service
- Looks for anomalies and unauthorized actions
- Monitors flow logs, CloudTrail, S3 data events, and DNS log activities
- Monitors for zero-day activities



Amazon GuardDuty

- Produces well-defined "findings"
- Uses proprietary machine learning and AI algorithms
- Based on a partnership with several companies including Trend, CrowdStrike, and Rapid7
- It is a regional service with prices based on quantity of events and log volumes



AWS GuardDuty Findings



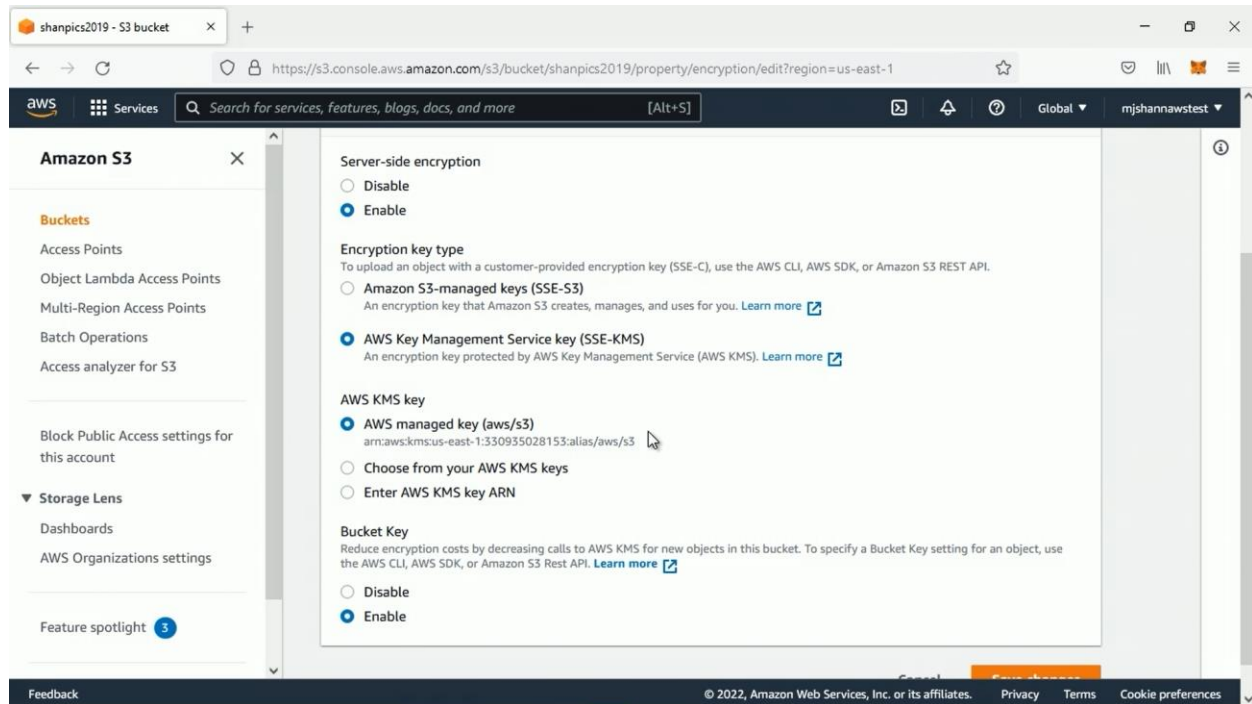
- **Backdoor**
 - Backdoor:EC2/C&CAActivity - EC2 - VPC flow logs - high severity
- **Behavior**
 - Behavior:EC2/NetworkPortUnusual - EC2 - VPC flow logs - medium severity
- **Credential Access**
 - CredentialAccess:IAMUser/AnomalousBehavior - IAM - CloudTrail - medium
- **Crypto Currency**
 - CryptoCurrency:EC2/BitcoinTool.B!DNS - EC2 - DNS logs - high
- **Defense Evasion**
 - DefenseEvasion:IAMUser/AnomalousBehavior - IAM - CloudTrail - medium
- **Discovery**
 - Discovery:S3/MaliciousIPCaller - S3 - S3 CloudTrail data event - high
- **Exfiltration**
 - Exfiltration:IAMUser/AnomalousBehavior - IAM - CloudTrail - high
- **Impact**
 - Impact:EC2/AbusedDomainRequest.Reputation - EC2 - DNS logs - medium

AWS GuardDuty Findings



- **Initial Access**
 - InitialAccess:IAMUser/AnomalousBehavior - IAM - CloudTrail - medium
- **Pen Test**
 - PenTest:IAMUser/KaliLinux - IAM - CloudTrail - medium
- **Persistence**
 - Persistence:IAMUser/AnomalousBehavior - IAM - CloudTrail - medium
- **Policy**
 - Policy:S3/BucketPublicAccessGranted - S3 - CloudTrail - high
- **Recon**
 - Recon:EC2/PortProbeEMRUnprotectedPort - EC2 - VPC flow logs - high
- **Stealth**
 - Stealth:IAMUser/CloudTrailLoggingDisabled - IAM - CloudTrail - low
- **Trojan**
 - Trojan:EC2/DNSDataExfiltration - EC2 - DNS logs - high
- **Unauthorized Access**
 - UnauthorizedAccess:S3/TorIPCaller - S3 - S3 CloudTrail data event - high

Using AWS Key Management Service (KMS)



AWS Artifact for AWS Compliance Documentation

AWS Compliance Benefits





AWS Artifact for AWS Compliance Documentation

- A console-based, on-demand and self-service auditing object retrieval service that offers quick and easy access to AWS Compliance documentation and agreements
- You may need to uphold specific standards, as proven through an audit
- An audit or inspection will ensure that the company has met those standards

AWS Artifact



A complete resource repository with access to all AWS auditor-supplied reports, certifications, accreditations, and other third-party verifications



A one-stop source for reviewing, admitting, and handling agreements for all current and future accounts in AWS Organizations



Supports the action of due diligence by achieving continuous visibility into security and compliance through immediate access to reports

AWS Artifact Agreements and Reports

- **AWS Artifact Agreements** – let you review, accept, and manage agreements for an individual account and for all your accounts in AWS Organizations
 - Different types of agreements are offered to address the needs of customers who are subject to specific regulations, such as HIPAA
- **AWS Artifact Reports** – provides compliance reports from third-party auditors who have tested and verified that AWS is compliant with a variety of global, regional, and industry-specific security standards and regulations
 - Remains up to date with the latest reports released
 - Can provide the AWS audit artifacts to your auditors or regulators as evidence of AWS security controls

CSA Consensus Assessments Initiative Questionnaire

Abstract

The CSA Consensus Assessments Initiative Questionnaire provides a set of questions the CSA anticipates a cloud consumer and/or a cloud auditor would ask of a cloud provider. It provides a series of security, control, and process questions which can then be used for a wide range of uses, including cloud provider selection and security evaluation. AWS has completed this questionnaire with the answers below. The questionnaire has been completed using the current CSA CAIQ standard, v3.1.1 (11-15-19 Update).

Audit Manager Console x CSA Consensus Assessments Initiati: x +

→ ↺ https://d1.awsstatic.com/whitepapers/compliance/CSA_Consensus_Assessments_Initiative_Questionnaire.pdf ☆

↑ ↓ 5 of 174 - + Automatic Zoom ▾

Introduction

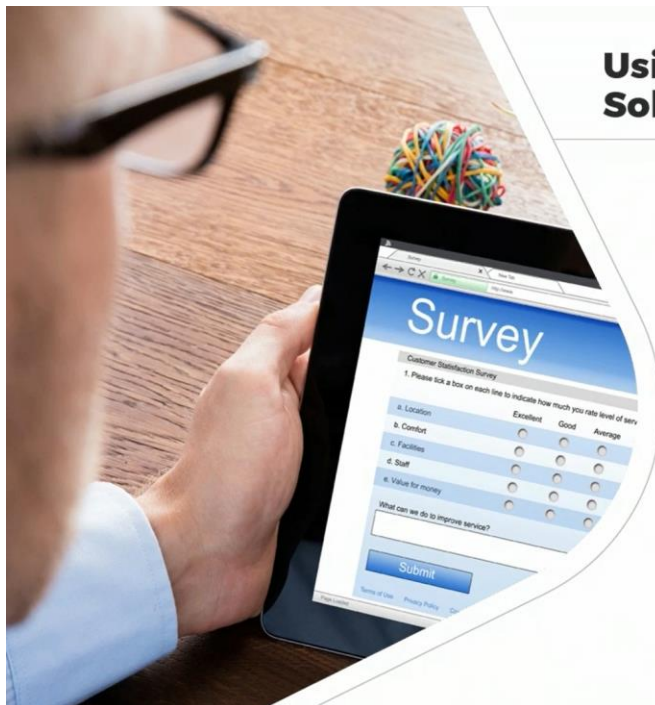
The Cloud Security Alliance (CSA) is a “not-for-profit organization with a mission to promote the use of best practices for providing security assurance within Cloud Computing, and to provide education on the uses of Cloud Computing to help secure all other forms of computing.” For more information, see <https://cloudsecurityalliance.org/about/>.

A wide range of industry security practitioners, corporations, and associations participate in this organization to achieve its mission.

CSA Consensus Assessments Initiative Questionnaire

Question ID	Consensus Assessment Questions	Answer			Notes	Control Responsibility
		Yes	No	N/A		
AIS-01.1	Do you use industry standards (i.e. OWASP Software Assurance Maturity Model, ISO 27034) to build in security for your Systems/Software	X			The AWS system development lifecycle incorporates industry best practices which include formal design reviews by the AWS Security Team, threat modeling and completion of a risk assessment.	AWS

Using the AWS Compliance Solutions Guide



Using the AWS Compliance Solutions Guide

- Contains resources to assist customers in learning more about AWS Compliance
- Contains customer compliance stories and case studies to ascertain how organizations in regulated industries have solved various compliance, governance, and audit tasks
- The Customer Compliance Center includes an AWS Auditor Learning Path designed for individuals in auditing, compliance, and legal roles who need to learn more about how their internal operations can validate compliance using the AWS Cloud



Using the AWS Compliance Solutions Guide

- Customers can access compliance whitepapers and documentation on topics such as
 - AWS answers to key compliance questions
 - An overview of AWS risk and compliance
 - An auditing security checklist

1. Which statement applies only to AWS Shield Advanced?
 - **It has access to deep visibility reporting and the 24x7 DDoS response team**
2. Which component is used to apply the web application firewall (WAF)?
 - **Web access control lists (web ACLs)**
3. Which fully managed threat detection service uses findings driven by proprietary machine learning and AI algorithms?
 - **Amazon GuardDuty**
4. Which feature serves as an optional layer of security for the VPC that acts as a stateless (static) firewall for controlling traffic in and out of one or more subnets?
 - **Network access control lists (NACLs)**

5. Which attribute relates specifically to security group firewalls?
 - **Stateful**

6. Which AWS resource contains customer compliance stories and case studies to ascertain how organizations in regulated industries have solved various compliance, governance, and audit tasks?
 - **Compliance Solutions Guide**

7. Which console-based, on-demand, self-service auditing object retrieval service offers quick and easy access to AWS Compliance documentation and agreements?
 - **AWS Artifact**

8. Which not-for-profit enterprise has a mission to promote the use of best practices for providing security assurance within cloud computing, and provides education on the uses of cloud computing to help secure all other forms of computing?
 - **Cloud Security Alliance (CSA)**

9. Which secure and resilient service uses hardware security modules to create, process, validate, and protect your cryptographic keys?
 - **AWS Key Management Service (KMS)**